

RISK ASSESSMENT FRAMEWORK

ISO/IEC 27001:2022-Aligned GRC Risk Assessment
RISK ASSESSMENT & COMPLIANCE REPORT

PREPARED BY
Areeb Amjad Khan

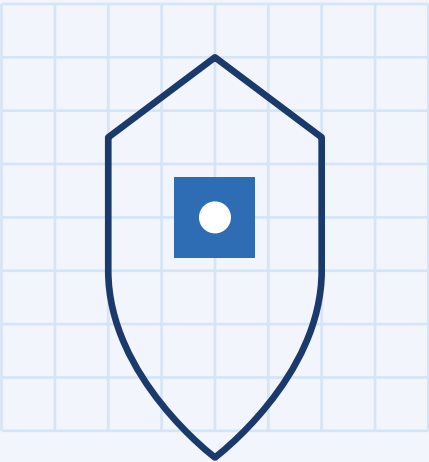
ORGANIZATION
Sample Organization

PROJECT ID
ZYNVEX-CERT-0666

REPORT TYPE
Full Risk Assessment

REPORT VERSION
1.0

GENERATED
16 August 2026, 17:08



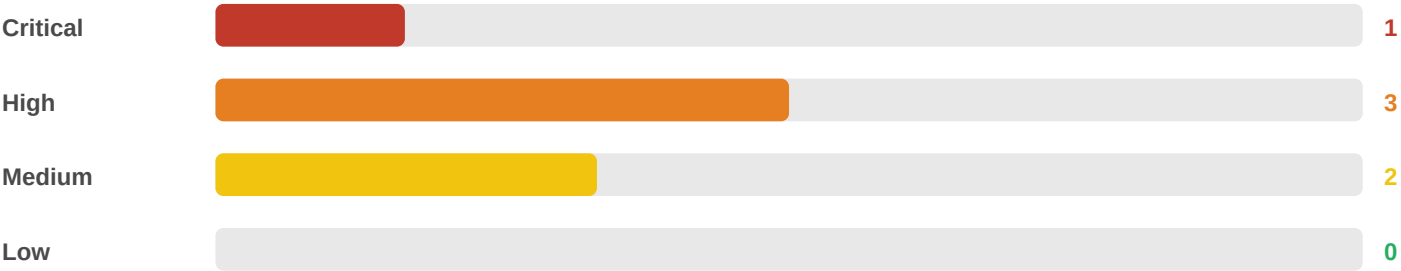
EXECUTIVE SUMMARY

Total Assets	Total Risks	Critical	High	Medium	Low	Applicable Controls	Risks w/o Treatment	Open Treatments	Overdue Treatments
5	6	1	3	2	0	11	0	4	0

RISK POSTURE

The current risk profile for Sample Organization contains **6** identified risks across **5** registered assets. This includes **1 Critical**, **3 High**, **2 Medium**, and **0 Low** risk items. **11** ISO/IEC 27001:2022 Annex A controls have been assessed as Applicable. **0** risks do not yet have a treatment plan, and **4** treatments are currently active.

RISK DISTRIBUTION



5x5 RISK MATRIX

The matrix plots each risk by Likelihood (X-axis) and Impact (Y-axis). Cell values show the Risk Score and count of risks in that position.

Impact \ Likelihood	1 Rare	2 Unlikely	3 Possible	4 Likely	5 Almost Certain
5 Severe	5 0 risks	10 1 risk	15 1 risk	20 1 risk	25 0 risks
4 Major	4 0 risks	8 1 risk	12 0 risks	16 1 risk	20 0 risks
3 Moderate	3 0 risks	6 0 risks	9 1 risk	12 0 risks	15 0 risks
2 Minor	2 0 risks	4 0 risks	6 0 risks	8 0 risks	10 0 risks
1 Insignificant	1 0 risks	2 0 risks	3 0 risks	4 0 risks	5 0 risks
Low (1–4)		Medium (5–9)		High (10–16)	Critical (17–25)

TOP RISKS

#	Risk Title	Asset	Score	Risk Level	Status
1	Unauthorized Access to Customer Database	Customer Database	20	Critical	Open
2	Web Application Exploitation	Web Application	16	High	Open
3	SQL Injection	Customer Database	15	High	Under Treatment
4	Backup Data Theft	Backup Server	10	High	Accepted
5	Malware Infection	Employee Laptops	9	Medium	Open
6	Unauthorized Network Access	Internal Network	8	Medium	Open

RISK REGISTER

Risk Title	Asset	Threat	L	I	Score	Risk Level	Owner	Status
Unauthorized Access to Customer Database	Customer Database	Credential Theft	4	5	20	Critical	DBA Lead	Open
SQL Injection	Customer Database	Malicious Actor	3	5	15	High	DevSecOps	Under Treatment
Web Application Exploitation	Web Application	Automated Scanners	4	4	16	High	Dev Team	Open
Malware Infection	Employee Laptops	Phishing Emails	3	3	9	Medium	IT Support	Open
Unauthorized Network Access	Internal Network	Insider Threat	2	4	8	Medium	Network Admin	Open
Backup Data Theft	Backup Server	Physical Intrusion	2	5	10	High	Storage Team	Accepted

ISO/IEC 27001:2022 — STATEMENT OF APPLICABILITY

11 Total	11 Applicable	0 Not Applicable	9 Implemented	2 Partial	2 Planned
-------------	------------------	---------------------	------------------	--------------	--------------

Organizational Controls

Control ID	Control Name	Applicability	Implementation Status
5.15	Access control	Applicable	Partially Implemented
5.16	Identity management	Applicable	Implemented

People Controls

Control ID	Control Name	Applicability	Implementation Status
6.3	Information security awareness, education and training	Applicable	Planned

Physical Controls

Control ID	Control Name	Applicability	Implementation Status
7.1	Physical security perimeters	Applicable	Implemented

Technological Controls

Control ID	Control Name	Applicability	Implementation Status
8.1	User endpoint devices	Applicable	Implemented
8.13	Information backup	Applicable	Implemented
8.25	Secure development life cycle	Applicable	Partially Implemented
8.26	Application security requirements	Applicable	Implemented
8.5	Secure authentication	Applicable	Planned
8.7	Protection against malware	Applicable	Implemented
8.8	Management of technical vulnerabilities	Applicable	Implemented

RISK TREATMENT PLAN

Risk	Treatment	Description	Owner	Target Date	Status	Inherent Score	Residual Score	Residual Level	Reduction
Unauthorized Access to Customer Database	Mitigate	Implement MFA, RBAC, privileged access review, and quarterly access recertification.	IT Security Team	2026-09-30	In Progress	20	10	High	50%
SQL Injection	Mitigate	Implement parameterized queries, input validation, secure code review, and regular application security testing.	DevSecOps	2026-10-15	Planned	15	5	Medium	67%
Malware Infection	Mitigate	Deploy endpoint protection, email filtering, patch management, and security awareness training.	IT Support	2026-03-01	Implemented	9	3	Low	67%
Backup Data Theft	Mitigate	Encrypt backups, restrict backup access, and implement secure offline/immutable backup storage.	Storage Team	2026-12-01	Planned	10	5	Medium	50%
Unauthorized Network Access	Accept	Current VLAN segregation is sufficient given the cost of network overhaul.	Network Admin	2026-01-01	Accepted	8	8	Medium	0%
Web Application Exploitation	Transfer	Engage a third-party managed security service provider (MSSP) to assume operational security responsibility for the web application platform.	CISO	2026-11-30	Planned	16	8	Medium	50%